GRC Portfolio Artifact | Executive Summary

Security Assessment & Remediation Summary

Ceraphin Energy Solutions (CES) ● Fictional critical-infrastructure, smart-grid, and cloud services company

Author: Alexander Dabbs

Purpose and Objective

This portfolio exercise demonstrates a focused Governance, Risk, and Compliance (GRC) workflow: review selected security controls, document observations and potential gaps, recommend corrective actions, and define how remediation could be tracked through closure. The scenario centers on cloud-based SCADA telemetry, AI-based energy forecasting, and operational technology (OT) cloud gateways. It is intended to demonstrate assessment and reporting practices, not to represent a real engagement.

Frameworks and Scope

Primary Framework: ISO/IEC 27001:2022, using five selected Annex A control areas. **Additional Context:** relevant NERC Critical Infrastructure Protection (NERC CIP) considerations were noted where applicable to the fictional scenario. This limited exercise does not establish full NERC CIP compliance, ISO 27001 certification, or conformity across all controls.

At-a-glance Results

5	2	1	2
Selected Controls	Compliant	Partial	Non-Compliant

Key Observations

CONTROL AREA	SCENARIO OBSERVATION	PROPOSED FOLLOW-UP
A.5.15 Access Control	Separate permissions are described for AI training and production SCADA environments; rated compliant based on described evidence.	Maintain least privilege and periodic access reviews; retain evidence of reviews and exceptions.
A.5.17 Authentication Information	Hardware-backed MFA is described for interactive remote sessions; effectiveness and supporting validation were not independently tested.	Periodically verify enforcement, exceptions, and supporting assurance documentation.
A.8.20 Network Security	The AI prediction API and corporate development cluster share upstream transit-gateway architecture, creating a potential segmentation concern.	Strengthen routing isolation and inspection; validate changes with documented tests.
A.8.23 Web Filtering	AI training workloads retrieve data from third-party domains without outbound proxy content filtering.	Restrict egress to approved destinations; retain configuration, test, and monitoring evidence.
A.5.24-A.5.26 Incident Response	Approved, scenario-specific response procedures and exercise for cloud SCADA and AI infrastructure were not provided.	Approve response procedures, define escalation responsibilities, run a tabletop, and track resulting actions.

Remediation Tracking Approach

The companion tracker translates observations into proposed actions with illustrative risks, accountable roles, target timelines, and evidence that support closure. For controls rated compliant, it records ongoing assurance rather than suggesting that monitoring can stop. In a real assessment, risk rating, ownership, dates, and closure criteria would need stakeholder confirmation and a documented risk methodology..

Important Caveats

- Findings reflected only the evidence and conditions described in the fictional scenario; no live systems were assessed.
- The exercise covers five selected control areas and is not a complete audit, certification assessment, or legal/regulatory determination.
- Documentary evidence alone does not prove operational effectiveness; independent testing was not performed.
- Risk rating, owners, remediation dates, and closure evidence are illustrative planning examples.

Fictional-company Disclaimer: Ceraphin Energy Solutions (CES), its systems, policies, evidence, control observations, and findings are fictional and created solely for this GRC portfolio project. Any resemblance to an actual organization, environment, or finding is coincidental. This document is a learning and demonstration artifact and should not be interpreted as an attestation of any real company's security or compliance status.